

- c. Has formality appropriate to the complexity of the institution.
- d. Considers the overall IT environment, regardless of the design and management of the IT environment.

Objective 10: Determine whether the institution maintains a risk identification process that is coordinated and consistent across the enterprise.

1. Determine whether the institution has a comprehensive IT risk identification process that includes the identification of cybersecurity risks. Specifically, determine whether management performs the following:
 - a. Maintains an inventory of assets, event classes, threats, and existing controls.
 - b. Participates in an information sharing forum (such as FS-ISAC).
 - c. Has a process to identify internal and external threats.
 - d. Considers existing controls—including governance of controls, their limitations, and their effectiveness—in a comprehensive control assessment.
 - e. Has a risk identification process that is formal yet flexible enough to adapt to changes in the IT environment.
 - f. Incorporates a measurement and assessment of outsourced relationships in the risk identification process.
 - g. Considers the information security risk assessments completed in accordance with the Information Security Standards in management oversight of IT operations.
2. Determine whether the institution's risk identification process includes the ongoing collection of information on the IT environment, including the following:
 - a. IT systems inventories.
 - b. IT strategic plans.
 - c. Interconnectivity documentation.
 - d. Information flow diagrams.
 - e. Business continuity and disaster recovery plans.
 - f. Third-party management program.
 - g. Call center data.
 - h. Department self-assessments.
 - i. IT audit findings.
 - j. Threat intelligence information.

Objective 11: Determine whether institution management maintains a risk measurement process that is coordinated and consistent across the enterprise.

1. Determine whether management's risk measurement process includes the determination of risk factors (such as adverse events, threats, and controls) and the affected assets. Determine whether management develops inventories of those risk factors. Specifically, determine whether management does the following in the risk measurement process:
 - a. Identifies reasonable threats to financial institution assets.

- b. Performs a threat analysis.
 - c. Estimates the probability of occurrence of adverse events.
 - d. Determines the potential impacts of events and threats, internal and external.
 - e. Analyzes the institution's technical and organizational vulnerabilities.
 - f. Measures risk through qualitative, quantitative, or hybrid measurement approaches.
 - g. Measures and assesses risks posed by third-party relationships.
 - h. Considers the information security risk assessments completed in accordance with the Information Security Standards in management oversight of IT operations.
 - i. Risk ranks information assets according to a rigorous and consistent methodology.
2. Determine whether the risk measurement process is comprehensive and includes the following types of risks that affect the institution:
 - a. Security breaches.
 - b. System failures.
 - c. External or insider events.
 - d. Development and acquisition issues.
 - e. Capacity planning issues.
 - f. Third-party provider issues.
 3. Identify whether the institution has a proactive process in place to effectively update its measurement of risk before implementing system changes, rolling out new products or services, or confronting new external conditions.

Objective 12: Determine whether financial institution management effectively implements satisfactory risk mitigation practices.

1. Determine whether the institution has processes within enterprise-wide risk management to assist IT management in making risk mitigation decisions, and determine which entities should be involved in the decision-making process.
2. Determine whether management has adequate methods and tools, including control self-assessments and scenario analysis, to evaluate controls for effectiveness against identified threats.
3. Determine whether the ITRM process addresses risks with an effective IT control structure in the institution's IT environment and through conformance with external legal and regulatory requirements.
4. Determine whether IT management has developed adequate policies, standards, and procedures to manage the risk from technology and that they are current, documented, and appropriately communicated. Policies, standards, and procedures should address the following:
 - a. Risk assessment.
 - b. Personnel administration.

- c. Development and acquisition, including secure development.
 - d. Computer operations.
 - e. Third-party risk management.
 - f. Computer and information security, including cybersecurity.
 - g. Business continuity and resilience planning.
 - h. IT audit.
5. Determine whether management has effective hiring and training practices that include the following:
 - a. Performing appropriate background checks on new staff, contractors, and third-party provider personnel, as necessary.
 - b. Confirming identity.
 - c. Obtaining character references.
 - d. Requiring periodic acknowledgement of acceptable-use policies.
 - e. Obtaining signed confidentiality and nondisclosure agreements.
 - f. Providing information security awareness and training programs.
6. Determine whether the board has appropriate oversight and management has appropriate responsibility for the implementation of the institution's information security program.
7. For the information security program, verify that the board is responsible for the following:
 - a. Overseeing the development, implementation, and maintenance of the program.
 - b. Assigning specific responsibility for its implementation.
 - c. Providing management with guidance and reviewing the effectiveness of management's actions.
 - d. Annually reviewing and approving a formal, written information security program.
 - e. Overseeing management steps to safeguard the information assets of the bank and its customers.
 - f. Annually reviewing management's report on the status of the bank's actions to achieve or maintain compliance with the Information Security Standards.
8. Determine whether, as part of the institution's information security program, the board of directors oversees and management establishes a control structure that is intended to specifically address cybersecurity risks and includes the following:
 - a. Developing and implementing processes to identify, protect against, detect, respond to, and recover from security events and incidents.
 - b. Developing, implementing, and periodically testing incident response procedures.
 - c. Using a threat intelligence and collaboration process to identify and respond to information on threats and vulnerabilities.
 - d. Including information security risks when developing, implementing, or updating products.
 - e. Assigning "business owner" responsibility in product development or update processes.

- f. Performing penetration tests before launching new or making significant changes to existing Internet- and client-facing applications and remediating findings from the tests.
 - g. Conducting initial due diligence and ongoing monitoring to fully understand the connections and mitigating controls in place between the financial institution and its third-party providers.
 - h. Implementing a governance process to establish, monitor, maintain, and test controls to mitigate interconnectivity risk.
 - i. Developing a policy for escalating and reporting security incidents to the board, government agencies, law enforcement, and the institution's primary federal and state regulators based on thresholds defined by the financial institution.
9. Determine whether the board of directors approved policies and management established and implemented policies, procedures, and responsibilities for an enterprise-wide business continuity program, including the following:
 - a. Annual review and approval of the business continuity program by the board of directors.
 - b. Management responsibility to document, maintain, and test the plan and backup systems periodically according to risk.
 - c. Annual reports by management of the results of the business continuity and disaster recovery tests to the board of directors.
10. Determine whether management assesses and mitigates the operational risks associated with the development or acquisition of software. Appropriate management of the risks should include the following:
 - a. Policies documenting risk management controls for the development and acquisition of systems.
 - b. System development life cycle or similar methodology based on the complexity and type of development performed.
 - c. Tests of new technology, systems, and products before deployment to validate functionality, controls, and interoperability.
 - d. Penetration tests of new or updated applications, particularly for Internet- or client-facing applications, to detect and correct security flaws.
11. Review major acquisitions of hardware and software to determine if the acquisitions are within the limits approved by the board of directors.
12. Determine whether management is aware of and mitigates operational risks associated with IT operations, including the following:
 - a. Data center or computer operations.
 - b. Network services.
 - c. Distributed computing.
 - d. Desktop computing.
 - e. Change management.
 - f. Project management.

- g. Security.
 - h. Resource management.
 - i. Contingency and resiliency planning.
13. Review the financial institution's insurance program and determine whether it is commensurate with the size, complexity, risks, and mitigation strategy of the institution. Determine the adequacy of insurance coverage (if applicable) for the following:
- a. Employee fidelity.
 - b. IT equipment and facilities.
 - c. Media reconstruction.
 - d. Extra expenses, including backup site expenses.
 - e. E-banking activities.
 - f. Business interruption.
 - g. Valuable papers and records.
 - h. Errors and omissions.
 - i. Items in transit.
 - j. Other probable risks (unique or specific risks for a particular institution).
14. Review the financial institution's third-party management program to ascertain the extent and effectiveness of the oversight by the board of directors and management of risks involved in the financial institution's outsourced relationships. An effective third-party management program should incorporate the following:
- a. A framework for management to identify, measure, mitigate, and monitor the risks associated with third-party relationships.
 - b. Board oversight and senior management development and implementation of enterprise-wide policies to govern the third-party management program.
 - c. A review process of third-party providers to ensure that each relationship supports the institution's overall business objectives and strategic plans.
 - d. Evaluation of prospective third-party providers based on the scope and criticality of services provided.
 - e. Tailoring of the monitoring program based on the initial and ongoing risk assessment of the third party and the services provided.
15. As part of the examiner's review of the institution's third-party management program, analyze the third party's financial condition and note any potential weaknesses, including measures to improve those weaknesses.
16. When reviewing information provided by the institution's third-party providers, determine whether the third-party provider enables adequate financial institution client access to relevant information. Consider the following:
- a. The third party's method of communication with financial institution clients.
 - b. Timeliness of third-party reporting to financial institution clients.
 - c. Quality of financial information, as determined by internal or external auditor reports.

17. When reviewing information provided by the institution's third-party providers, determine the adequacy of third-party provider audit reports in terms of scope, independence, expertise, frequency, and corrective actions taken on identified issues. Work with the examiner reviewing the third-party management program to determine its adequacy.
18. When reviewing information provided by the institution's third-party providers, determine the quality of management's follow-up and resolution of customer concerns and problems with its third-party providers.

Objective 13: Determine whether IT management develops satisfactory measures for defining and monitoring metrics, performance benchmarks, service level agreements, compliance with policies, effectiveness of controls, and quality assurance and control. Determine whether management developed satisfactory reporting of ITRM activities.

1. Determine whether management develops and uses metrics to help assess the overall IT environment. Determine whether the metrics used and the frequency and monitoring of those metrics are useful to direct management's attention to emerging issues. Additionally, determine whether necessary metrics or summary reports of metrics are provided to the board.
2. Determine whether there are established performance benchmarks and standards for the IT function and whether they serve to help management identify problem areas, particularly in system or data center availability, operating conditions, response times, and error rates.
3. Review whether the institution has formal service level agreements with all of its third-party providers. Determine whether the agreements provide the institution with assurance of continued service.
4. Determine the effectiveness of management's communication and monitoring of IT policy compliance across the institution.
5. Determine whether management has an adequate method of testing the effectiveness of control design and implementation and whether management and the board appropriately monitor risk mitigation activities. Determine whether management considers all forms of controls, including governance of controls, their limitations, and their effectiveness in a comprehensive control assessment.
6. Determine whether management has QA and QC procedures defined for significant IT activities and whether those procedures are performed internally or externally. Specifically, review whether management:
 - a. Has a process to assist it in determining whether products or services meet specified requirements (QA).
 - b. Has procedures to ensure that a product or application adheres to a defined set of quality criteria to meet end-user requirements (QC),

- c. Performs tests associated with QA and QC independent of the programming function, and whether the QA and QC procedures incorporate user acceptance testing programs.
 - d. Receives effective reports on the results of QA and QC testing.
- 7. Review the monitoring and reporting specific to the institution's ITRM activities. Specifically, determine whether the institution has developed the following:
 - a. A process to adequately identify and monitor relevant external threats and vulnerabilities.
 - b. Effective risk monitoring that provides tangible feedback on the quality of the implementation of controls and risk mitigation strategies.
 - c. A reporting process that assembles and reports IT risk-related information in a timely, complete, transparent, and relevant manner.
 - d. Appropriate escalation procedures in place depending on the content of the reporting.

Objective 14: Discuss corrective action and communicate findings.

- 1. Review preliminary conclusions with the examiner-in-charge (EIC) regarding:
 - a. Violations of laws and regulations.
 - b. Significant issues warranting inclusion as matters requiring attention or recommendations in the report of examination.
 - c. Proposed Uniform Rating System for Information Technology management component rating and the potential impact of the examiner's conclusions on composite or other component IT ratings.
 - d. Potential impact of the examiner's conclusions on the institution's risk assessment.
- 2. Discuss findings with management and obtain proposed corrective action for significant deficiencies.
- 3. Document conclusions in a memorandum to the EIC that provides report-ready comments for all relevant sections of the report of examination and guidance to future examiners.
- 4. Organize work papers to ensure clear support for significant findings by examination objective.

Appendix B: Glossary

Access: The ability to physically or logically enter or make use of an IT system or area (secured or unsecured). The process of interacting with a system.

Administrator privileges: Computer system access to resources that are unavailable to most users. Administrator privileges permit execution of actions that would otherwise be restricted.

Agility: In IT systems, the ability to rapidly incorporate new technologies or changes to technologies allowing an organization to adapt to changing business needs.

Application development: The process of designing and building code to create a computer program (software) used for a particular type of job.

Benchmark: A standard, or point of reference, against which things may be compared or assessed.

Confidentiality: Assuring that information will be kept secret, with access limited to appropriate persons.

Control self-assessment: A technique used to internally assess the effectiveness of risk management and control processes.

Corrective control: A mitigating technique designed to lessen the impact to the institution when adverse events occur.

Cyber attack: An attempt to damage, disrupt, or gain unauthorized access to a computer, computer system, or electronic communications network. An attack, via cyberspace, targeting an institution for the purpose of disrupting, disabling, destroying, or maliciously controlling a computing environment/infrastructure; or destroying the integrity of the data or stealing controlled information.

Cybersecurity: The process of protecting consumer and bank information by preventing, detecting, and responding to attacks.

Data center: A facility that houses an institution's most important information systems components, including computer systems, telecommunications components, and storage systems.

Detective control: A mitigating technique designed to recognize an event and alert management when events occur.

Disaster recovery: The process of recovering from major processing interruptions.

Due diligence: Technical, functional, and financial review to verify a service provider's ability to deliver the requirements specified in its proposal. The intent is to verify that the service

provider has a well-developed plan and adequate resources and experience to ensure acceptable service, controls, systems backup, availability, and continuity of service to its clients.

Enterprise Architecture: The overall design and high-level plan that describes an institution's operational framework and includes the institution's mission, stakeholders, business and customers, work flow and processes, data processing, access, security, and availability.

Enterprise-wide: Across an entire organization, rather than a single business department or function.

External connections: An information system or component of an information system that is outside of the authorization boundary established by the organization and for which the organization typically has no direct control over the application of required security controls or the assessment of security control effectiveness.

Financial Services Information Sharing and Analysis Center (FS-ISAC): A nonprofit, information-sharing forum established by financial services industry participants to facilitate the public and private sectors' sharing of physical and cybersecurity threat and vulnerability information.

Gramm–Leach–Bliley Act: The Gramm–Leach–Bliley Act (GLBA), also known as the Financial Services Modernization Act of 1999 (Pub.L. 106-102, 113 Stat. 1338, enacted November 12, 1999), required the Federal banking agencies to establish information security standards for financial institutions.

Incident management: The process of identifying, analyzing, and correcting disruptions to operations and preventing future recurrences. The goal of incident management is to limit the disruption and restore operations as quickly as possible.

Information security: The process by which an organization protects the creation, collection, storage, use, transmission, and disposal of information.

Information systems: Electronic systems and physical components used to access, store, transmit, protect, and eventually dispose of information. Information systems can include networks (computer systems, connections to business partners and the Internet, and the interconnections between internal and external systems). Other examples are backup tapes, mobile devices, and other media.

Information technology: Any services or equipment, or interconnected system(s) or subsystem(s) of equipment that comprise the institution's IT architecture or infrastructure. It can include computers, ancillary equipment (including imaging peripherals, input, output, and storage devices necessary for security and surveillance), peripheral equipment designed to be controlled by the central processing unit of a computer, software, firmware and similar procedures, services (including cloud computing and help-desk services or other professional services which support any point of the life cycle of the equipment or service), and related resources.

Infrastructure: Describes what has been implemented by IT architecture and often include support facilities such as power, cooling, ventilation, server and data redundancy and resilience, and telecommunications lines. Specific architecture types may exist for the following: enterprise, data (information), technology, security, and application.

Interconnectivity: The state or quality of being connected together. The interaction of a financial institution's internal and external systems and applications and the entities with which they are linked.

Interdependencies: Where two or more departments, processes, functions, and/or third parties affect or support one another.

Internet: A worldwide network of computer networks, governed by standards and protocols developed by the Internet Engineering Task Force (IETF).

Interoperability: The ability of a system to work with or use the parts or equipment of another system.

IT architecture: A subset of enterprise architecture, with detail to support data processing and access, including fundamental requirements for centralized or distributed computing, real or virtual servers, devices and workstations, and networking design. Architecture plans may also exist for data (information), security, and applications.

IT governance: An integral part of governance that consists of the leadership and organizational structures and processes that ensure that the organization's IT sustains and extends the organization's strategies and objectives.

IT strategic plan: A comprehensive blueprint that guides the organization's technology management and contains high-level goals and plans for all areas of information technology that affect the business, not just the infrastructure. The plan should include areas that impact technology management, including cost management, human capital management, hardware and software management, third-party management, risk management, and all other considerations in the enterprise IT environment.

IT system inventory: A list containing information about the information resources owned or operated by an organization.

Malware: Software designed to secretly access a computer system without the owner's informed consent. The expression is a general term (short for malicious software) used to mean a variety of forms of hostile, intrusive, or annoying software or program code. Malware includes computer viruses, worms, trojan horses, spyware, dishonest adware, ransomware, crimeware, most rootkits, and other malicious and unwanted software or programs.

Metric: A quantitative measurement.